Cross-platform Mobile Apps & Security

Andrii Shalaginov
andrii.shalaginov@kristiania.no

Associate Professor @ Department of Technology

TEK306: Sikkerhet i mobile applikasjoner, 01.11.2021

Content

- OWASP & Cybersecurity
- Types of Mobile Apps, Cross-platform App Development
- Security in Cross-platform Apps
- Scripting Attacks
- Domain Whitelisting
- Examples

Cybersecurity landscape

ENISA Threat Landscape 2020



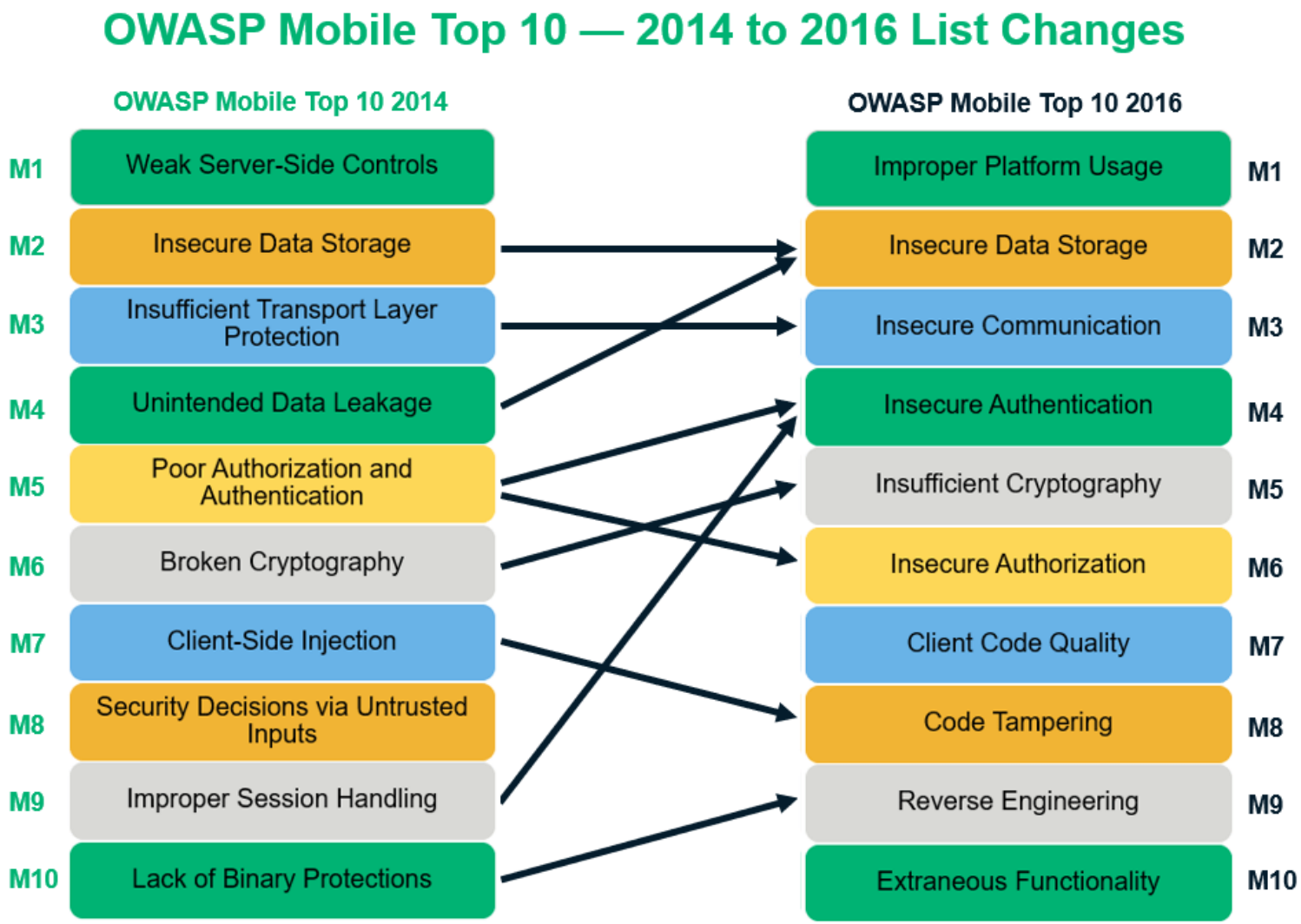
https://www.enisa.europa.eu/news/enisa-news/enisa-threat-landscape-2020

OWASP Top 10

- The OWASP Mobile Security Project is a centralized resource intended to give developers and security teams the resources they need to build and maintain secure mobile applications. Through the project, our goal is to classify mobile security risks and provide developmental controls to reduce their impact or likelihood of exploitation. The project is a breading ground for many different mobile security projects within OWASP.



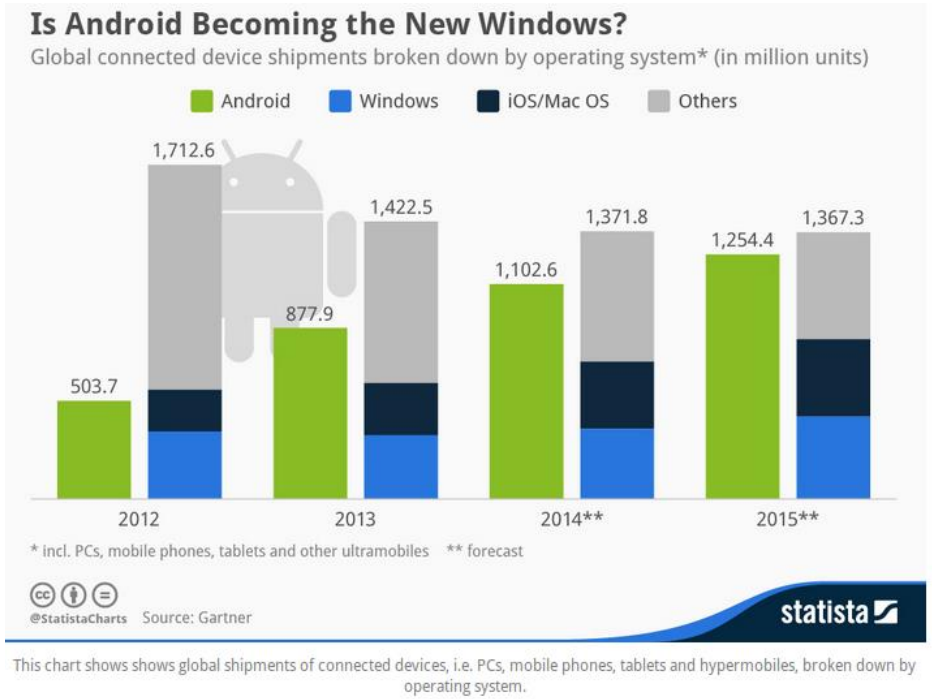
OWASP Top 10


OWASP Mobile Top 10 — 2014 to 2016 List Changes
OWASP Mobile Top 10 2014
OWASP Mobile Top 10 2016
M1
Weak Server-Side Controls
M2
Insecure Data Storage
M3
Insufficient Transport Layer Protection
M4
Unintended Data Leakage
M5
Poor Authorization and Authentication
M6
Broken Cryptography
M7
Client-Side Injection
M8
Security Decisions via Untrusted Inputs
M9
Improper Session Handling
M10
Lack of Binary Protections
Improper Platform Usage
M1
Insecure Data Storage
M2
Insecure Communication
M3
Insecure Authentication
M4
Insufficient Cryptography
M5
Insecure Authorization
M6
Client Code Quality
M7
Code Tampering
M8
Reverse Engineering
M9
Extraneous Functionality
M10

Mobile Applications

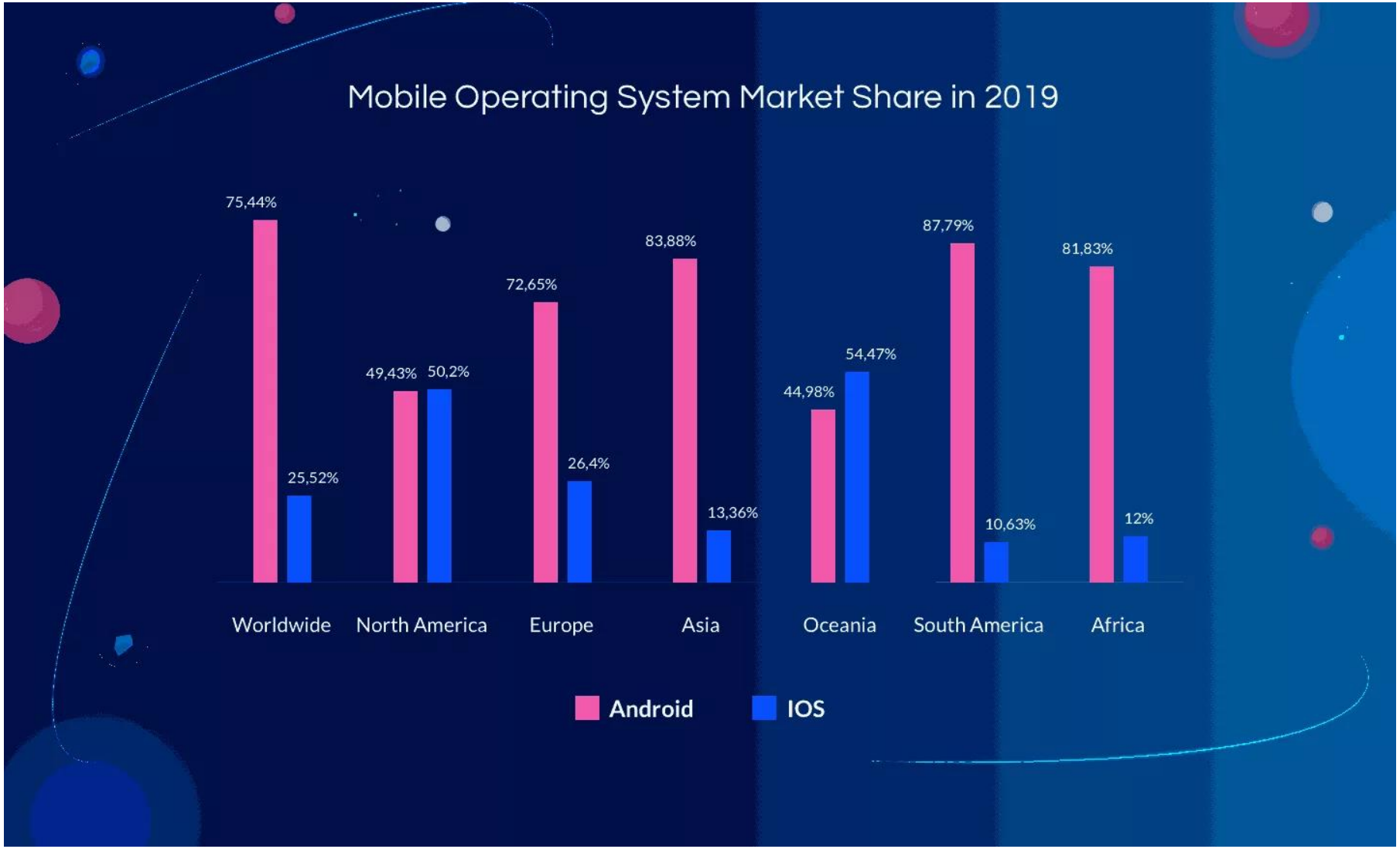
OPERATING SYSTEMS: 2015…





http://www.whatisall.com/what-is-mobile-os/
http://sourcedigit.com/1913-smartphone-os-global-market-share-data-2014/

OPERATING SYSTEMS: 2019...



IMPORTANCE OF MOBILE SECURITY

Stored data

- SMS History
- Deleted SMS
- Contacts (stored in phone memory and on SIM card)
- Call History (Received Calls, Dialed Numbers, Missed Calls) Datebook
- Scheduler
- Calendar
- File System (physical memory)
- GPS Waypoints, Tracks, Routes, etc.
- RAM/ROM
- Databases
- E-mail

STORED DATA

PCWorld

		iOS 6	Android 4.0	Windows Phone
		iOS6	Android 4.0	WP 7.5
Maps	Turn by Turn Directions	✔	✔	✘
	3D/Fly-over/Aerial Mode	✔	✔	✔
	Street View	✘	✔	✘
Voice	Voice Commands	✔	✔	✔
	Dictation	✔	✔	✔
Photo Streaming		✔	✔ via Google+	✔ via SkyDrive
Social	Facebook Integration	✔	✔ 3rd party apps only	✔
	Twitter Integration	✔	✔ 3rd party apps only	✔
	Content Sharing	✔	✔	✔
Mail: Priority/VIP labels		✔	✔	✘
Browser	Unified URL/Search Bar	✔	✔	✔
	Tab/Bookmark Sync	✔	✔ via Google Chrome	✘
	Reading List	✔ + Offline	✔ + Offline	✘
Phone	Call filtering	✔	✔	✘
	Call reply actions	✔	✔	✘
Messaging: Cross Platform		✔	✔	✔
Notifications		✔	✔	✘
Video Chat		✔ 3G + Wi-Fi	✔ 3G + Wi-Fi	✔ 3rd party apps only 3G + Wi-Fi
Device Recovery		✔	✘	✔

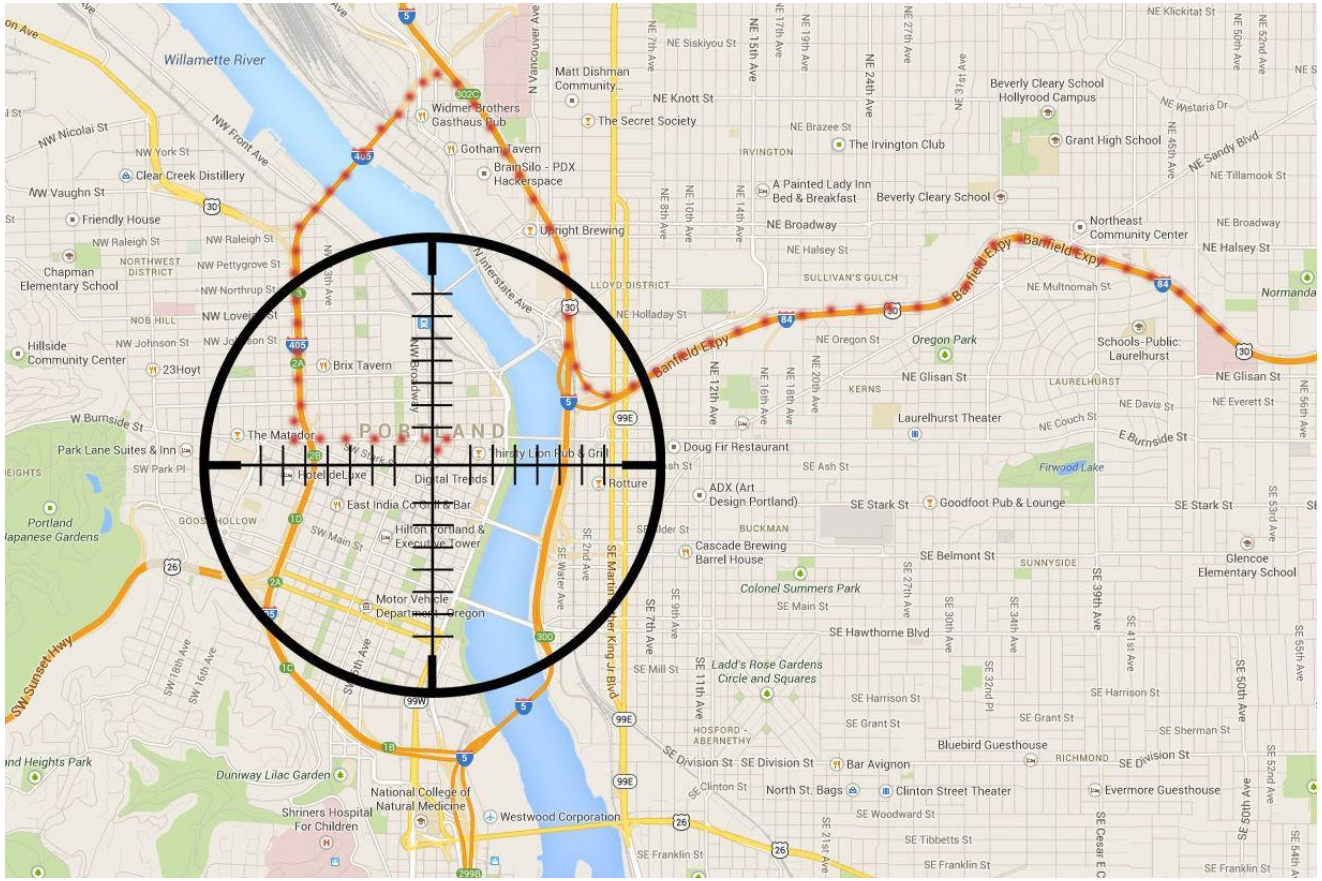
http://www.techhive.com/article/257363/apples_ios_6_vs_android_and_windows_phone.html

STORED DATA (2) - APPLICATIONS



http://thenextweb.com/google/2012/01/27/google-apps-dominate-the-indian-android-experience-but-lose-the-social-network-audience/
http://www.tappin.com/blog/2012/10/expand-mobile-device-memory/

STORED DATA (3) - GPS



http://www.digitaltrends.com/mobile/how-to-track-a-cell-phone/

ANDROID SECURITY

Permission-based access control - user “to blame”

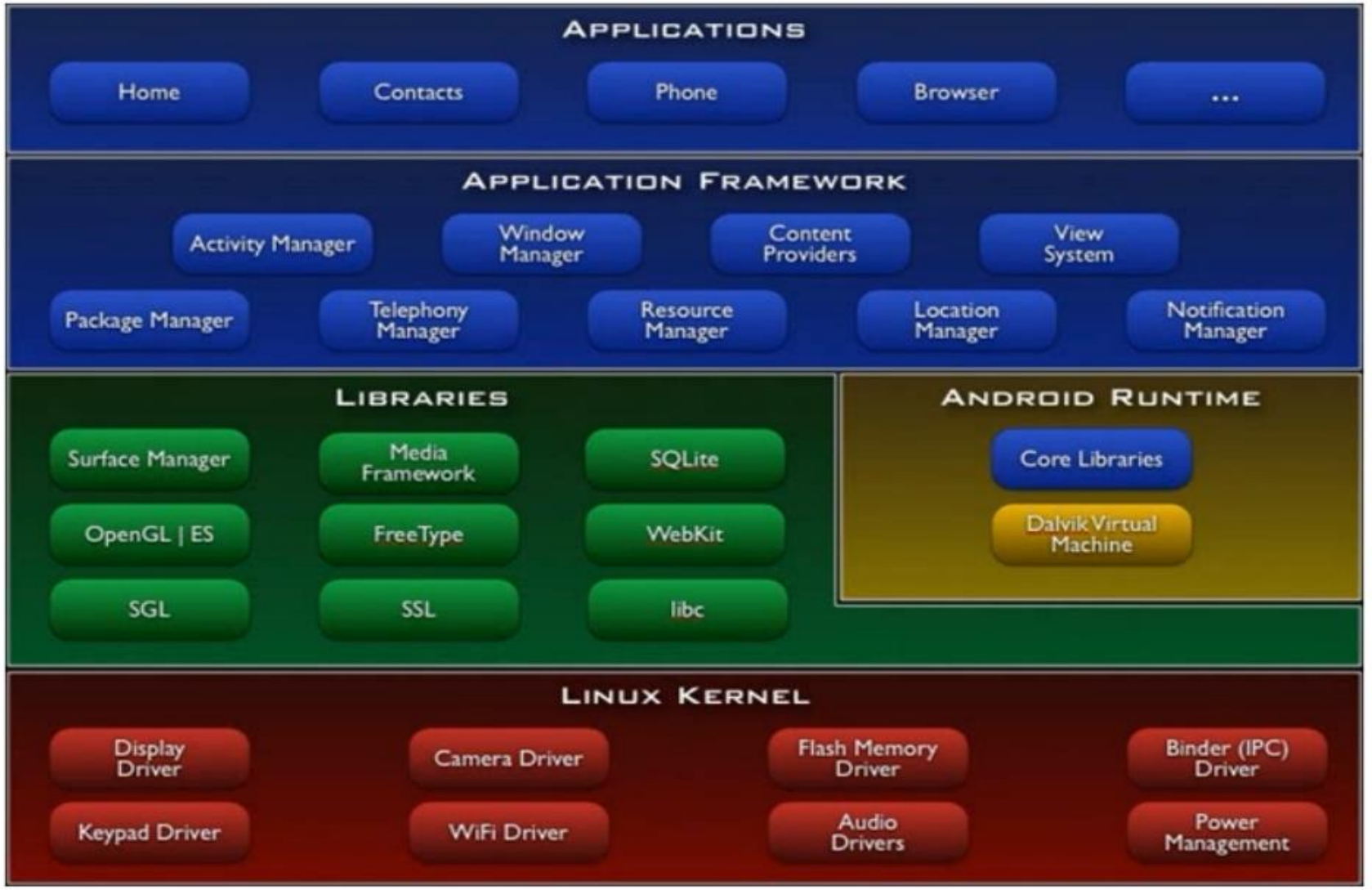
Filesystem access

3rd party apps distribution markets



https://www.clickssl.com/blog/android-vulnerability-99-devices-at-risk-of-victimization

ANDROID SECURITY - ARCHITECTURE



http://www.dhunju.com/2012/01/android-architecture.html

ANDROID EMULATOR

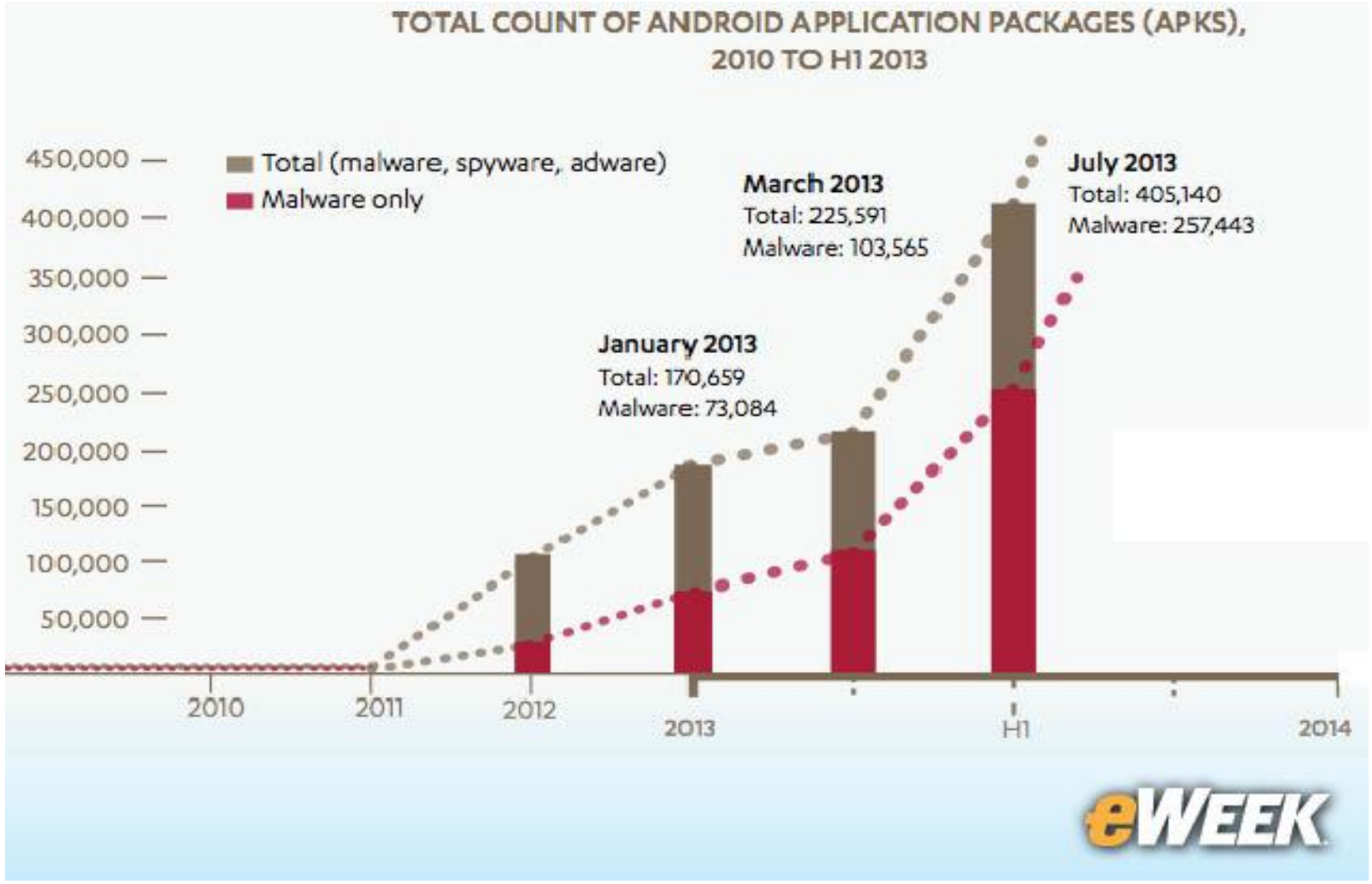


http://developer.android.com/tools/help/emulator.html

ANDROID SECURITY

- PC ⇒ mobile
- Huge storage AND **Sensitive data**
- Large amount of applications
- **Official market** (Google Play) ⇒ certified developers, signed validated apps
- Third-party markets ⇒ malware?
- Permissions-based model in mobile OS
- Signature-based AV (MD5 hash sums, Reverse engineering, System artifacts)

ANDROID MALWARE - WHERE IT ALL STARTED



http://www.eweek.com/security/slideshows/security-stats-show-mobile-malware-xss-as-top-concerns.html

Android: use-case

Why is it so popular for mobile viruses developers?

And so many security issues as a result…

ANDROID-SPECIFIC DATA

Data Folder (in /data/data) Structure	`|-- dump_image`
	`|-- e2fsck`
	`|-- erase_image`
	`|-- fix_permissions`
	`|-- flash_image`
	`|-- parted`
	`|-- preparecloudbackup.sh`
	`|-- preparepartition.sh`
	`|-- preparewipedalvikcache.sh`
	`|-- reboot`
	`|-- sdparted`
	`|-- tegra_flash_image`
	`-- tune2fs`
	
	`2 directories, 20 files`

Data Bases extracted content (file,table,content)	`Array`
	`(`
	`[google_analytics.db] => Array`
	`(`
	`[android_metadata] => en_US`
	`)`
	`[settings.db] => Array`
	`(`
	`[android_metadata] => en_US`
	`)`
	`)`

Shared Preferences xml content (file,content)	*Unavailable!*

Requested Permissions	`android.permission.ACCESS_WIFI_STATE`
	`android.permission.WRITE_EXTERNAL_STORAGE`
	`android.permission.READ_PHONE_STATE`
	`android.permission.INTERNET`
	`android.permission.WAKE_LOCK`
	`android.permission.ACCESS_NETWORK_STATE`
	`android.permission.GET_ACCOUNTS`
	`android.permission.USE_CREDENTIALS`
	`permission: com.koushikdutta.rommanager.permission.C2D_MESSAGE`
	`com.koushikdutta.rommanager.permission.C2D_MESSAGE`
	`com.google.android.c2dm.permission.RECEIVE`
	`com.android.vending.BILLING`

A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

3RD PARTY APPS

Name	Size	Type	Date Modified
ninesky.browser_120.apk	1.1 MB	Android package	Fri 10 May 2013 05:05:34 PM CEST
CM_Music.apk	1.1 MB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo++v1.1.apk	2.4 MB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo_v1.0_for_4.1_by_JD_Team.apk	410.0 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo_v1.0_Folder_Support.apk	435.2 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollov1.1_rus.apk	2.4 MB	Android package	Fri 10 May 2013 03:29:20 PM CEST
ApolloThemes+Jelly+Bean+2.apk	1.2 MB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo+Jelly+Bean+Theme.apk	395.2 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo-Dark_by_ATs.apk	756.8 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo__3_.apk	439.9 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo__1_.apk	434.2 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Apollo.apk	398.8 kB	Android package	Fri 10 May 2013 03:29:20 PM CEST
Circle_Weather_v_1.4.7.apk	849.0 kB	Android package	Fri 10 May 2013 01:07:00 PM CEST
Circle_Weather_v.1.4.7_Rus_by_Azat_777.apk	817.8 kB	Android package	Fri 10 May 2013 01:07:00 PM CEST
dolphinmini2.2.apk	1.0 MB	Android package	Fri 10 May 2013 12:21:10 PM CEST
Dolphin_Browser_Mini_2.2_RusBlue.apk	910.2 kB	Android package	Fri 10 May 2013 12:21:10 PM CEST

DATA IN THE FILESYSTEM

Name	Size	Type	Date Modified
data	2 items	folder	Sun 26 May 2013 11:38:46 AM CEST
databases	2 items	folder	Sun 26 May 2013 11:38:46 AM CEST
webview.db	41.0 kB	SQLite3 database	Tue 07 May 2013 11:05:42 PM CEST
webview.db-journal	8.7 kB	unknown	Tue 07 May 2013 11:05:42 PM CEST
shared_prefs	1 item	folder	Sun 26 May 2013 11:38:46 AM CEST
appBehaviour.xml	111 bytes	XML document	Tue 07 May 2013 11:05:40 PM CEST
screenshot.png	133.5 kB	PNG image	Tue 07 May 2013 11:05:32 PM CEST
trace.txt	131.8 kB	plain text document	Tue 07 May 2013 11:05:40 PM CEST
traffic.cap	708.3 kB	Network Packet Capture	Tue 07 May 2013 11:05:48 PM CEST
traffic.xml	452.6 kB	XML document	Tue 07 May 2013 11:05:42 PM CEST

A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

FUNCTION CALLS TRACES – USER SENSITIVE INFO

```
10:28:19.546735 bind(31, {sa_family=AF_INET6, sin6_port=htons(0), inet_pton(AF_INET6, "::", &sin6_addr), sin6_flc
10:28:19.547023 getsockname(31, {sa_family=AF_INET6, sin6_port=htons(56069), inet_pton(AF_INET6, "::", &sin6_addr
10:28:19.547179 connect(31, {sa_family=AF_INET6, sin6_port=htons(80), inet_pton(AF_INET6, "::ffff:46.252.18.96",
.....................................................................................................
10:28:19.801006 sendto(31, "POST /wat.php HTTP/1.1\r\nContent-"..., 201, 0, NULL, 0) = 201
10:28:19.802290 sendto(31, "SECOND_TABLE=0&imei=000000000000"..., 291, 0, NULL, 0) = 291
10:28:19.803522 recvfrom(31,  <unfinished ...>
.....................................................................................................
10:28:20.357153 writev(3, [{"\6", 1}, {"name\0", 5}, {"Ivan Petrov\0", 12}], 3) = 18
10:28:20.357663 mprotect(0xa0012000, 8192, PROT_READ|PROT_WRITE) = 0
.....................................................................................................
10:28:20.369316 writev(3, [{"\6", 1}, {"send sms\0", 9}, {"476-666-66\0", 11}], 3) = 21
10:28:20.369518 mprotect(0xa6fb8000, 4096, PROT_READ|PROT_WRITE) = 0
.....................................................................................................
10:28:20.406970 bind(31, {sa_family=AF_INET6, sin6_port=htons(0), inet_pton(AF_INET6, "::", &sin6_addr), sin6_flc
10:28:20.407121 getsockname(31, {sa_family=AF_INET6, sin6_port=htons(49913), inet_pton(AF_INET6, "::", &sin6_addr
10:28:20.407274 connect(31, {sa_family=AF_INET6, sin6_port=htons(80), inet_pton(AF_INET6, "::ffff:46.252.18.96",
.....................................................................................................
10:28:20.512993 sendto(31, "POST /wat.php HTTP/1.1\r\nContent-"..., 275, 0, NULL, 0) = 275
10:28:20.514712 recvfrom(31,  <unfinished ...>
```

A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

RUNNING APPLICATIONS



A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

INTERCEPTED TRAFFIC

Time	Source	Destination	Protocol	Length	Info
43.062187	10.0.2.15	10.0.2.3	DNS	73	Standard query A ibbeancom.com
58.521002	10.0.2.15	10.0.2.3	DNS	85	Standard query A xuesenlin.w44
59.202760	10.0.2.15	114.80.156.144	TCP	74	43897 > http [SYN] Seq=0 Win=5
59.510315	10.0.2.15	114.80.156.144	TCP	60	43897 > http [ACK] Seq=1 Ack=1
59.514878	10.0.2.15	114.80.156.144	HTTP	253	GET /setting.txt HTTP/1.1
69.458037	10.0.2.15	114.80.156.144	TCP	60	43897 > http [ACK] Seq=200 Ack
69.505911	10.0.2.15	114.80.156.144	TCP	60	43897 > http [ACK] Seq=200 Ack
108.922776	10.0.2.15	114.80.156.144	TCP	60	43897 > http [RST, ACK] Seq=20
33.412789	10.0.2.15	173.194.65.100	TCP	74	59846 > http [SYN] Seq=0 Win=5
33.447035	10.0.2.15	173.194.65.100	TCP	60	59846 > http [ACK] Seq=1 Ack=1
33.449706	10.0.2.15	173.194.65.100	HTTP	243	GET /generate_204 HTTP/1.1
33.484537	10.0.2.15	173.194.65.100	TCP	60	59846 > http [ACK] Seq=190 Ack=
46.845206	10.0.2.15	208.73.210.171	TCP	74	47129 > http [SYN] Seq=0 Win=5
47.030063	10.0.2.15	208.73.210.171	TCP	60	47129 > http [ACK] Seq=1 Ack=1
47.042496	10.0.2.15	208.73.210.171	HTTP	254	POST /entry.php?id=4 HTTP/1.1
47.226273	10.0.2.15	208.73.210.171	TCP	60	47129 > http [FIN, ACK] Seq=20
47.234526	10.0.2.15	208.73.210.171	TCP	74	35817 > http [SYN] Seq=0 Win=5
47.425231	10.0.2.15	208.73.210.171	TCP	60	35817 > http [ACK] Seq=1 Ack=1

A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

IP Information for 208.73.210.171

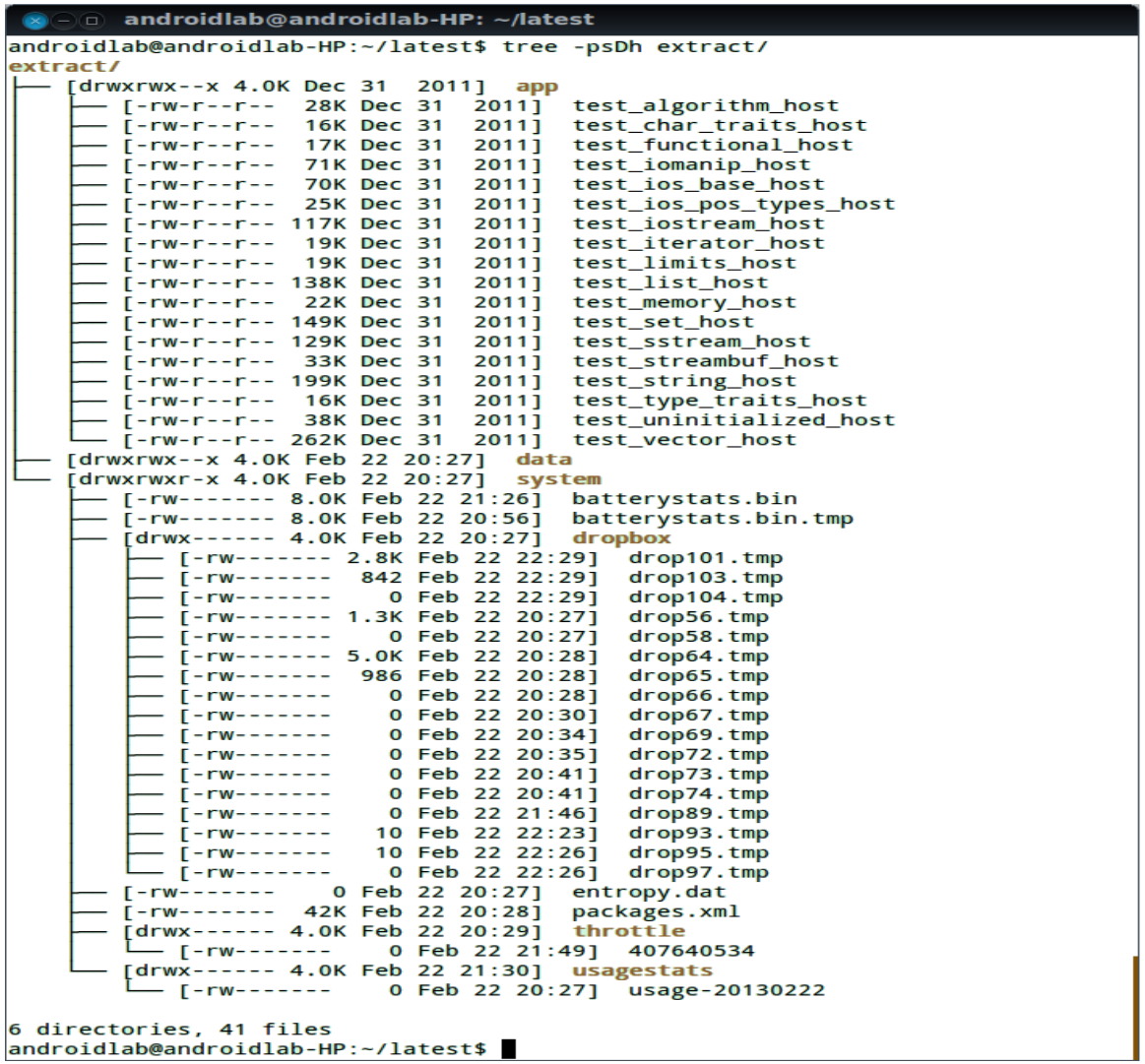
IP Location:	United States Los Angeles Oversee.net
ASN:	AS33626 OVERSEE-DOT-NET - Oversee.net (registered Feb 08, 2005)
Resolve Host:	sp7.information.com
IP Address:	208.73.210.171 W R P D T
Whois Server	whois.arin.net
Reverse IP:	2,831 websites use this address. (examples: kawasakidirect.org lifecareuk.com brasileira.org massaged.org)

```
NetRange:       208.73.208.0 - 208.73.215.255
CIDR:           208.73.208.0/21
OriginAS:
NetName:        OVERSEE-NET-2
NetHandle:      NET-208-73-208-0-1
Parent:         NET-208-0-0-0-0
NetType:        Direct Assignment
RegDate:        2006-12-28
Updated:        2013-01-14
Ref:            http://whois.arin.net/rest/net/NET-208-73-208-0-1

OrgName:        Oversee.net
OrgId:          OVERS-1
Address:        515 S. Flower St
Address:        Suite 4400
City:           Los Angeles
StateProv:      CA
PostalCode:     90071
Country:        US
RegDate:        2003-08-01
Updated:        2008-11-10
Ref:            http://whois.arin.net/rest/org/OVERS-1
```

A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

APPLICATIONS DATA FOLDERS



A. Shalaginov, *Automatic rule-mining for malware detection employing Neuro-Fuzzy Approach*, 2012-2013

Mobile Applications

Types of applications

Types of Mobile Apps

- Fragmentation challenges







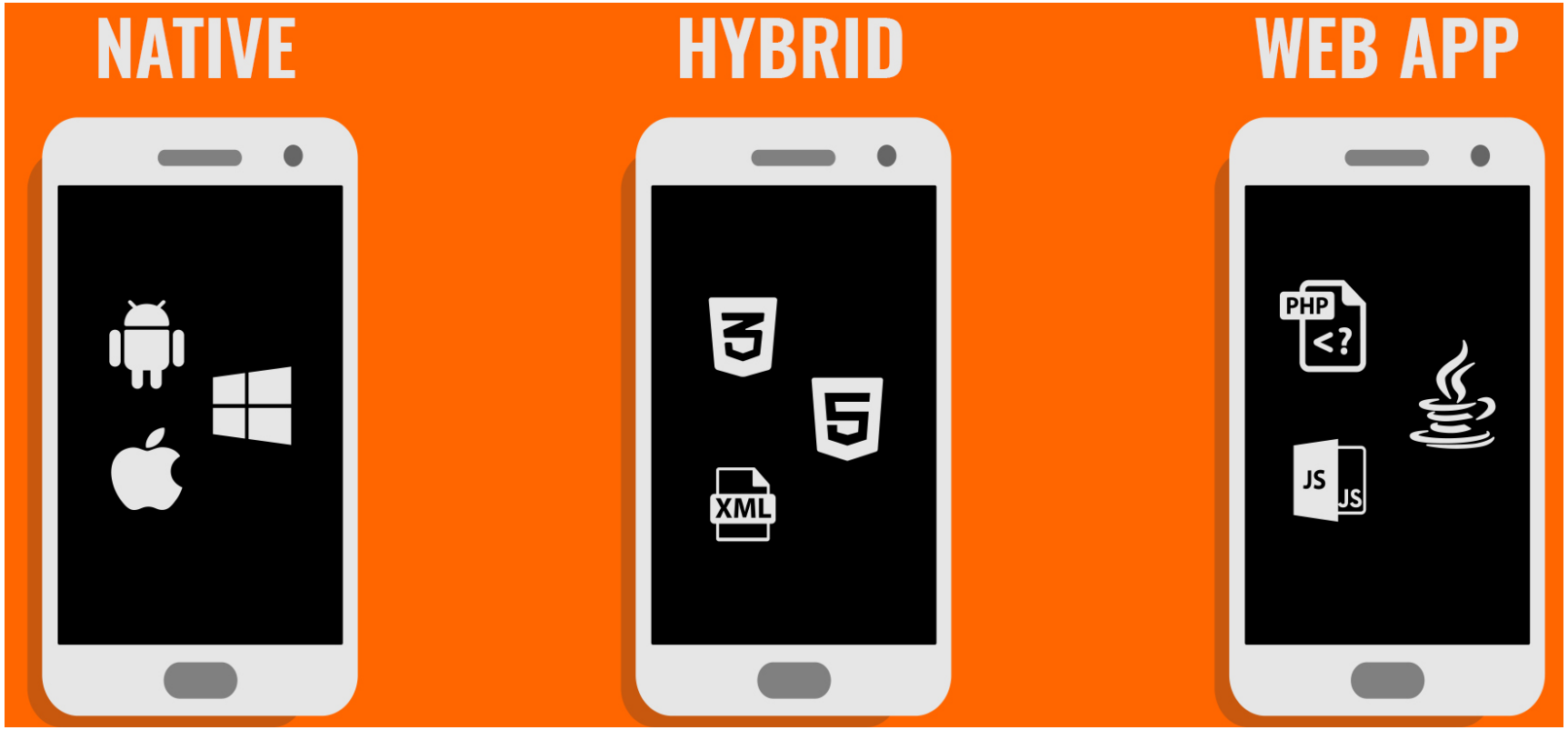
Multiple Teams/Products

Source: synerzip.com

Types of Mobile Apps …

- What are the technologies used to implement each of types of mobile apps?
- In what circumstances can one choose to use each type of mobile app?
- The advantages and disadvantages of each type …

Types of Mobile Apps …



Native development (1)

Native development is the development of apps that have a codebase that is created to run on a specific operating system — iOS or Android (or any other). For instance, Instagram, despite looking quite similar on both OSs, is represented by two native apps with separate codebases. The applications were written separately to target the users of both operating systems.

Native development has its benefits and drawbacks.

Advantages:

- **Native apps are fast**
- **Maximum benefits and easy access to push notifications**
- **Ability to access a phone's native features**

Native development (2)

Besides, native apps are high-performing and fast. Despite all the benefits you get with native apps, this type of development has a set of inefficiencies which we are going to underline further.

Disadvantages:

- **Excessive spending on the budget**
- **Resource-consuming development**
- **Slow delivery and launch of apps**
- **Difficulty in support**

Cross-platform mobile development (1)

Cross-platform mobile development is another type of app development that allows your product to run on multiple mobile operating systems and is written in a single programming language. When the code for an app is ready, it goes through a middleware that translates it into the native APIs of iOS or Android.

Advantages:

- **Fast development in a short period of time**
- **Cost-effectiveness**
- **Reusable code**
- **Perfect business-opportunity to engage a large share of the mobile app market**

Cross-platform mobile development (2)

Disadvantages:

- **Limited access to native features**
- **Issues with user experience**

With cross-platform development, you will have limited opportunity to a phone's feature set as all devices have different functionality. As a result, you might deal with some issues regarding user experience, because all devices have their own functionality and platforms. Thus it makes a cross-platform mobile app less competitive compared to native apps.

Native Apps

When to

High Performance Apps

Heavy on OS and Device Features

Complex Network comm.

Canvas based Apps

Only Few Platforms

When not to

Performance is not the main criteria

Replicates Web Apps with few device features

Standard RESTful

Widget based apps

Many platforms

Hybrid Apps

When to

Performance is not the main criteria

Replicates Web Apps with few device features

Standard RESTful

Widget based apps

Many platforms

Time to market is critical

Saving cost is critical

When not to

High performance Apps

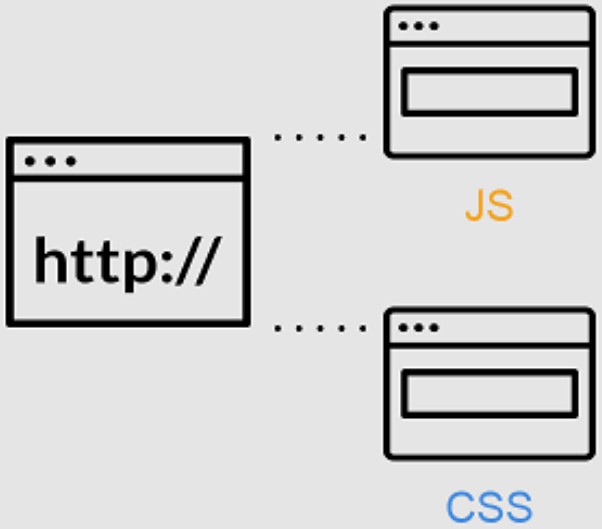
Heavy on OS and device features

Complex Network comm.

Canvas based Apps

Only few platforms

What is a website?

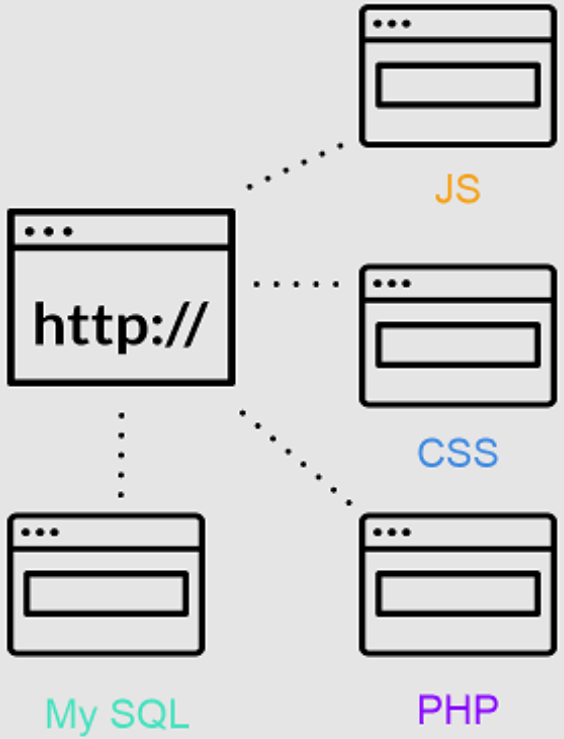


Is a group of interlinked and well-structured webpages that exist on the same domain.

The main goal: to display information to visitors.

https://dinarys.com/blog/website-vs-webapplication

What is a Web App?



A software program that exists on the server and runs using a website browser, through a web page.

Created using a combination of programming languages and web application frameworks.

It may use the RAM, allow user interactivity and it`s designed for many users.

The main goal: to interact with users, response user`s various request.

https://dinarys.com/blog/website-vs-webapplication

Web Application vs Website

Web Application

Dinamic pages:

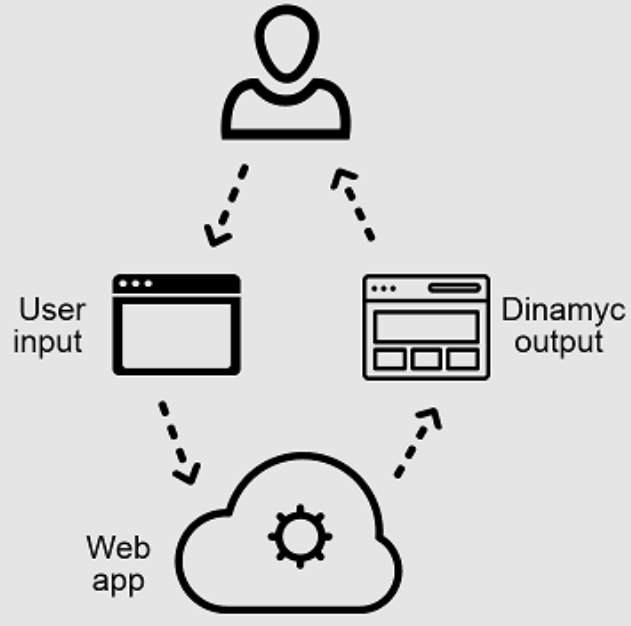
Every user sees the different information each time.



Website

Static pages:

Every user sees the same information each time.



https://dinarys.com/blog/website-vs-webapplication

Web Apps

- Mobile Web App? .. mobile friendly Web
- Website vs Web page? Web App vs Website?
- More Web Apps- https://dinarys.com/blog/website-vs.-webapplication

Types of Mobile Apps … comparing

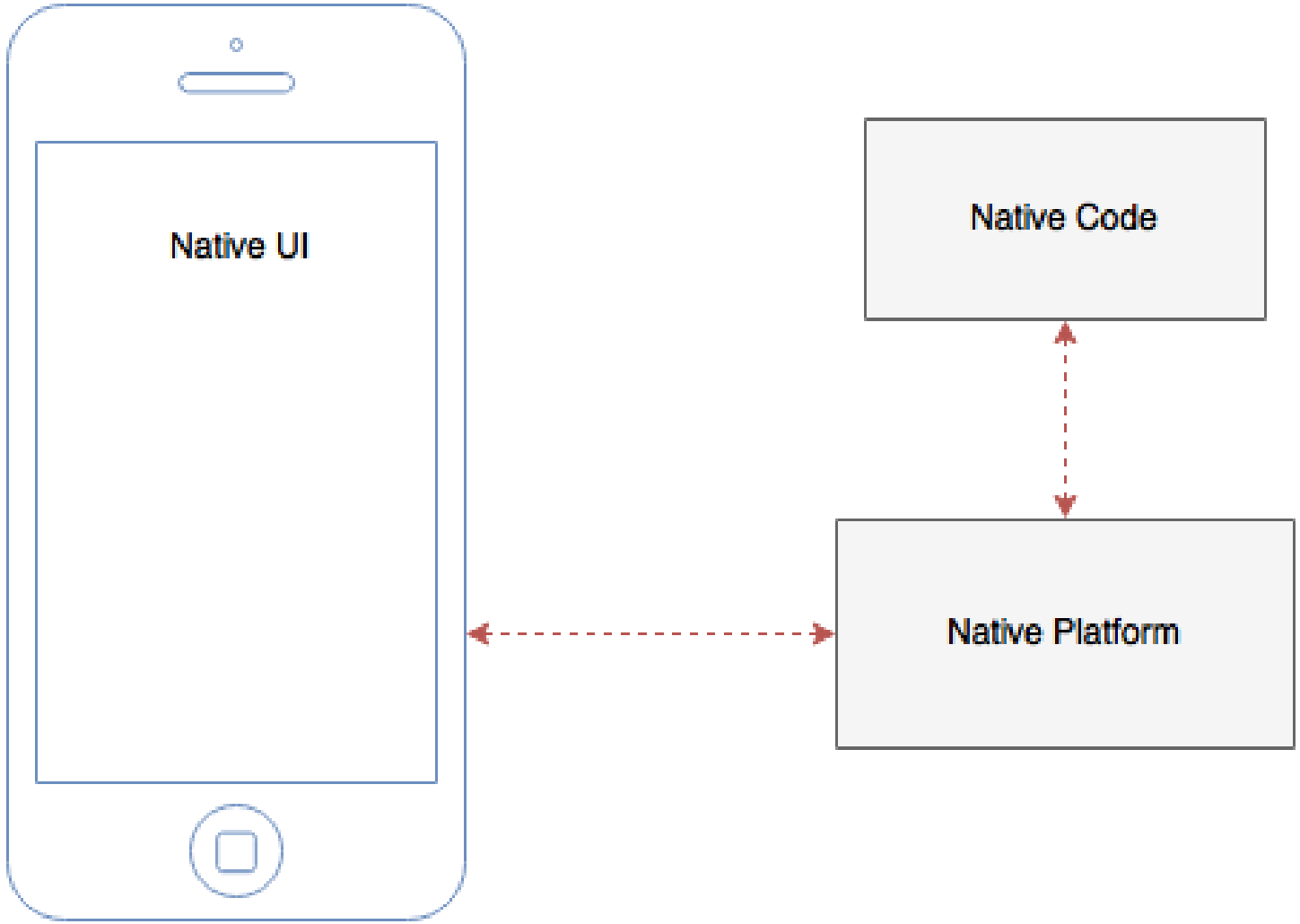
- Further readings on types of Apps-

  https://steelkiwi.com/blog/how-choose-correct-platform-mobile-app-development/

- Types of Mobile Apps (video)-

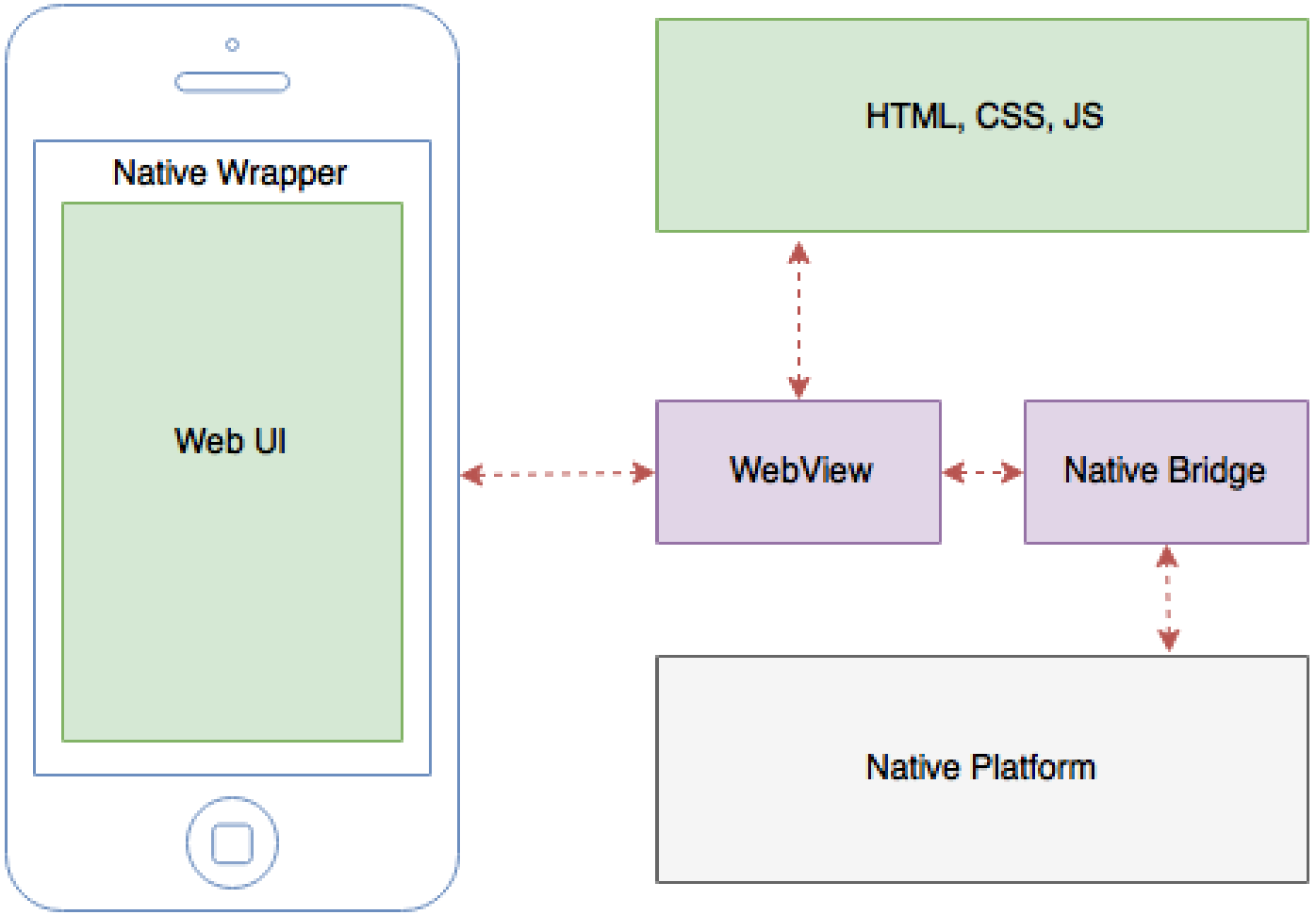
  https://www.mobiloud.com/blog/native-web-or-hybrid-apps#4

Native App



https://medium.com/applantic/mobile-applications-in-2018-part-i-comparison-native-vs-hybrid-be16a4067a9b

Hybrid application

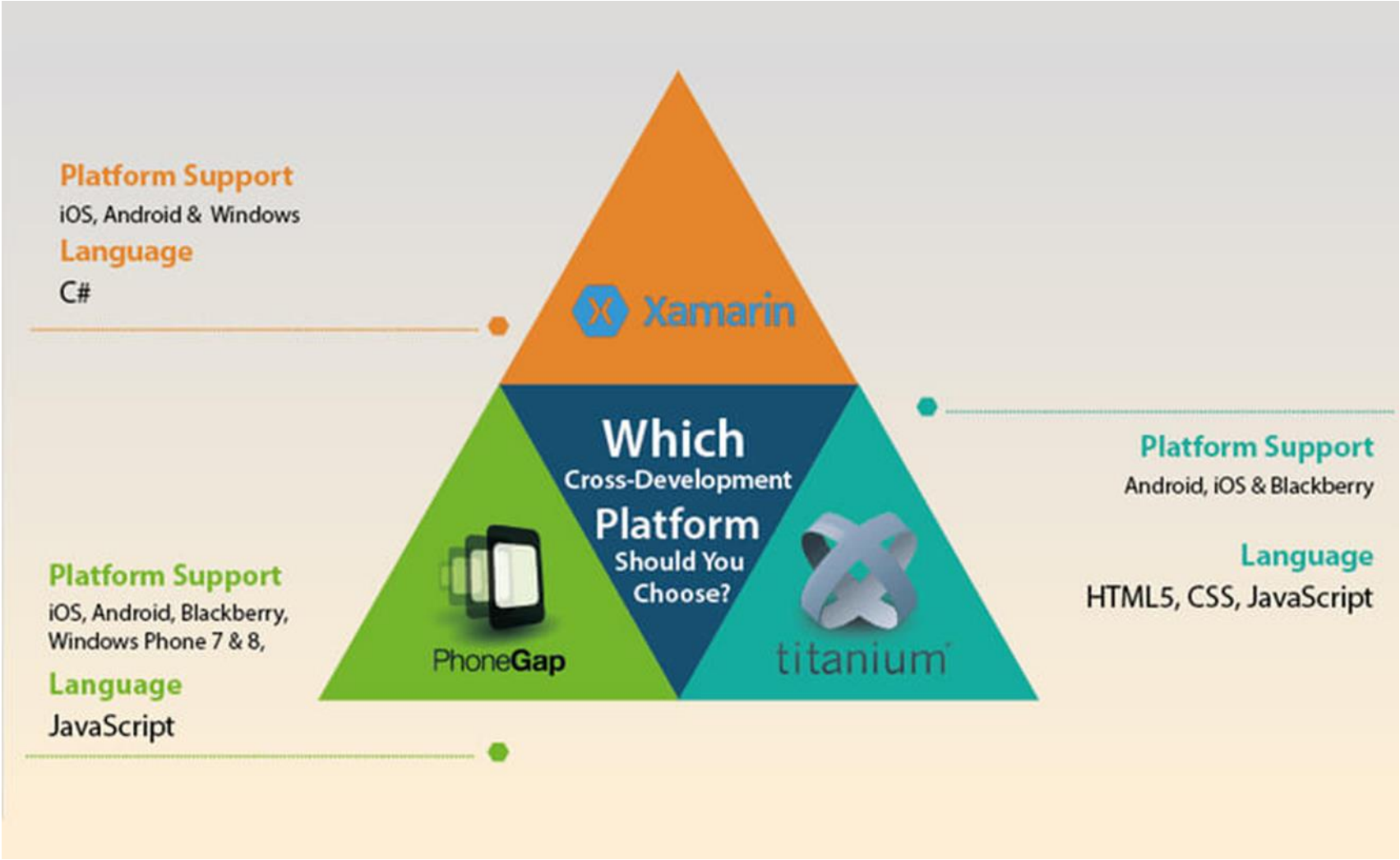


https://medium.com/applantic/mobile-applications-in-2018-part-i-comparison-native-vs-hybrid-be16a4067a9b

Cross-platform App Development

- Web development for common UI.
- Native code for heavy weight programming.
- Use frameworks like PhoneGap plugin development framework to glue the above two pieces.
- Use automation to regress every layer.

Cross-platform App Development …



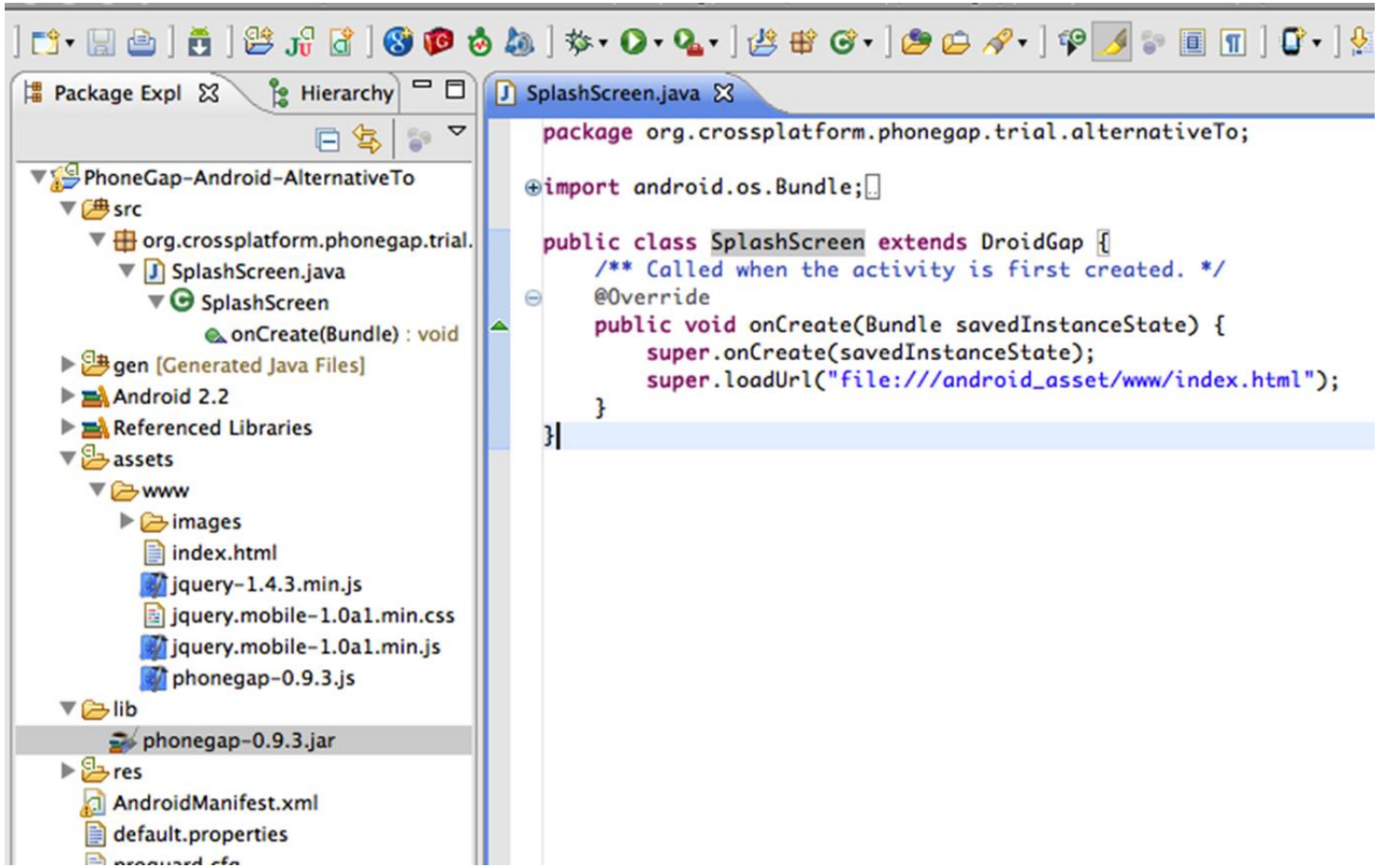
Cross-platform Mobile Development Tools and Their Adopters



Coding Example in PhoneGap

- We extend DroidGap instead of an Activity.
- Internally, DroidGap uses WebView (show HTML, JavaScript, and CSS more like Web 2.0 Apps).
- WebView has hooks to call Java from JavaScript and Vice a Versa.
- It makes a calls to JavaScript to allow access to native mobile-resources (e.g. Geo, Database, File, etc.)

Coding Example in PhoneGap …



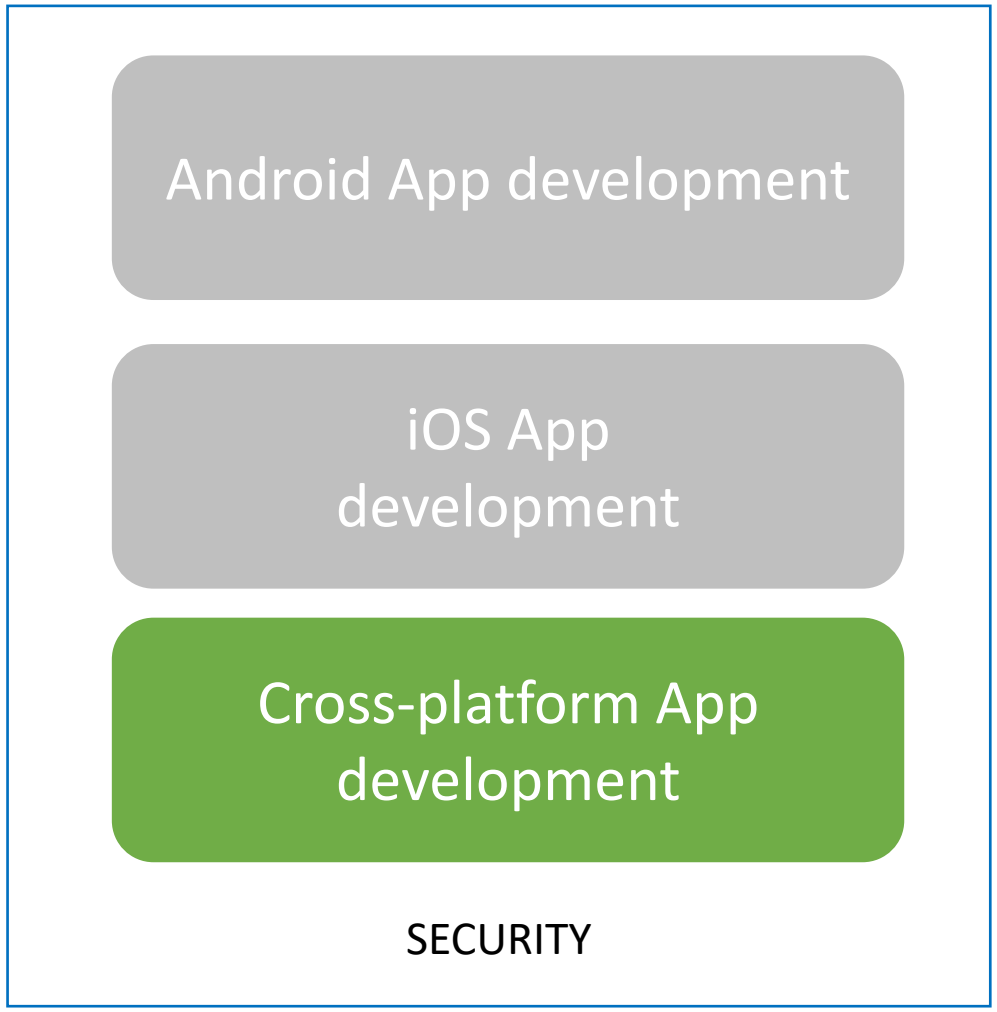
Other dev’t frameworks

- React Native
- Xamarin
- Ionic
- AngularJS

The trend

- WebKit as being the next virtual machine, which may go beyond the limits of Java.
- HTML5, CSS3 and JavaScript is the set of technology that lessens the fragmentation.
- HTML5 will compete with native components.

Security in Cross-platform Apps



Features of PhoneGap API

- Accelerometer- accesses device's motion sensor.
- Camera- captures photo using the device's camera.
- Compass- obtains direction of the device pointing.
- Contacts- works with the device's contact database.
- Filesystem- hooks into the device's file system.

Features of PhoneGap API …

- Geolocation- accesses the device's GPS location.
- Media- accesses (records) videos, audio or images.
- Network- performs accesses or requests network.
- Notifications- accesses visual device notifications.

Security in PhoneGap

- The PhoneGap frameworks did not come under the scrutiny of the security community.
- As the technology is a blend of native and Web, the testing methods in Web and native are applicable.
- However, a number of framework-specific security considerations are available.

Security Comes First



https://mindsea.com/security-hybrid-apps-vs-native-apps/

Hybrid apps more vulnerable

- hybrid apps are more vulnerable to attack than mobile apps written in native binary code because JavaScript and HTML typically require less skill to reverse engineer and tamper with.
- Because the app is actually running in a web browser with all of the browser capabilities around it, it’s also easier for attackers to pull off techniques like remote man-in-the-middle attacks, where data is intercepted as it is transmitted.
- Attackers can use these flaws to steal information stored or sent by the app, which could include sensitive data such as financial and personal details, or biometric details used for authentication.

https://www.mobileworldlive.com/apps/focus-apps/hybrid-apps-more-vulnerable-security-specialist-says

Hybrid apps: protection

- One of the most effective and accessible approaches to securing hybrid apps, according to Whaley, is to “combine obfuscation with runtime protection techniques and apply them to the JavaScript or HTML code embedded within the app”.
- Anti-tamper controls can be woven into the code, enabling it to checksum itself in runtime. Each time the hybrid app is opened, it will check its own code to confirm it is in its original state and has not been tampered with.
- The app will also be able to determine if it was booted up in a normal mobile device, rather than the sandbox environments attackers typically use when hacking apps.

https://www.mobileworldlive.com/apps/focus-apps/hybrid-apps-more-vulnerable-security-specialist-says

List of measures (1)

- **Keeping up to date** with the latest framework and plugins version. From time to time, vulnerabilities are also found in the framework and plugins used when developing the mobile application. Therefore, when it comes to framework and plugins, developers need to make sure they are using the latest version. This will ensure security with all the known risks to date.
- **Cross-site scripting** is one of the most frequent vulnerabilities found in web and hybrid development. Given it is a common risk, developers need to implement an improved solution so that an attacker is not able to inject client side scripts.
- **URLs whitelisting.** When building a hybrid app, each developer will know which URLs the app will connect with. Whitelisting only these URLs will help, so the app is only able to connect with the specific URLs.

List of measures (2)

- **Input encoding.** When the application has a data inputting function, attackers can always attempt to insert malicious content that can damage the application's server side. Each input has to be treated as important and an encoding mechanism should be applied to minimise such risks.
- **Communication with server.** When a mobile application interacts with the server, it is necessary to make use of SSL (Secure Sockets Layer). This is the standard technology used to date in order to keep connections between two systems safe. Important data is sent to and received by the application while communicating with the server, so it is important that SSL is used at all times.
- **Code obfuscation.** When building a hybrid app, code obfuscation is an ideal method to use. If the code is stolen and easy to read, the application would be susceptible to malicious attacks. Code obfuscation would allow for app reverse engineering and will make it more challenging for attackers.

Scripting Attacks

- Cross-platform frameworks depend on WebView- the embedded browser availability in different platforms.
- So, attacker-controlled data populated into WebView, causes cross-application (XAS) or cross-site scripting (XSS) attacks.

Cross-Application Scripting

- XAS is a vulnerability affecting desktop apps that don't check input in an exhaustive way. Wikipedia
- An example of XAS is when an arbitrary URL is populated into Cordova WebView when a third-party app invokes an intent.

Cross-Application Scripting …

- CSS is a type of security vulnerability typically found in web apps- hence not considered XAS.
- It enable attackers to inject client-side scripts into web pages viewed by other users.
- Such vulnerability are used by attackers to bypass access controls like same-origin policy. Wikipedia

XAS Attacks Scenarios

- Tainted data from a server-side Web App (XSS) populated to the WebView.
- Arbitrary URLs passed through IPC mechanisms (XAS) are loaded.
- Data loaded via IPC into a WebView and dynamically populated into a JavaScript block (XAS).

Domain Whitelisting

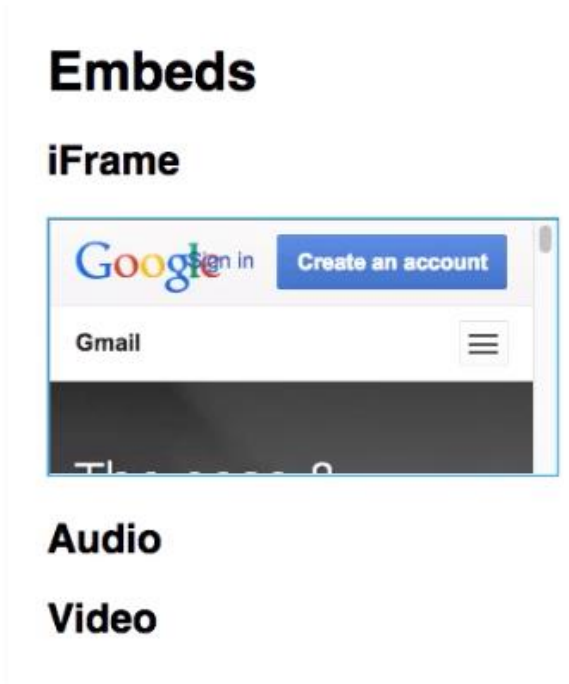
- Domain whitelisting is a security control in PhoneGap.
- It defines external domains that are from outside of the app's control- explicitly allowing to get access, privilege, service, mobility or recognition.
- Whitelisted domains have access to the Cordova JavaScript objects and corresponding Cordova bridge.
- It can be configured using the app's config.xml file as <access origin="https://mobileapphacker.com" />.
- Example of insecure whitelist- allowing unrestricted access to any domain <access origin="*"/>.

Iframes/Callbacks

- If a whitelisted domain loads content via an iframe the loaded content also has access to the bridge.
- Example of whitelisting an advertising network- ads loaded by iframe may accidentally expose Cordova bridge to any third-party sites.
- This means a malicious ad could do any actions that the Cordova app itself could perform.
- There is one exception to this that when Cordova is used on iOS, all URLs are intercepted.

Iframes/Callbacks …

```
1  <!DOCTYPE html>
2  <html lang="">
3  <head>
4    <meta charset="UTF-8">
5    <meta name="viewport"
   content="width=device-width, initial-
   scale=1.0">
6    <link rel="stylesheet"
   href="css/style.css">
7    <title>Form</title>
8  </head>
9
10 <body>
11   <div class="wrap">
12     <h1>Embeds</h1>
13
14     <h2>iFrame</h2>
15     <iframe src="https://gmail.com"
   frameborder="2"></iframe>
16
17     <h2>Audio</h2>
18
19     <h2>Video</h2>
20
21   </div>
22 </body>
23 </html>
24
```



Encrypted Storage

- Cordova's file system APIs do not support encryption.
- Instead, it relies on the default behaviour of the platform.
- Cordova apps running on the iOS platform inherit default protection.
- However, encryption is not supported by default in other platforms- content may be stored in plaintext.
- Among the solutions to this could be using platform-specific methods like Android keystore or iOS keychain.

More on Secure Protocols

- Xamarin security:
  - Xamarin's Transport Layer Security (TLS) for- Android and iOS
  - Local Security Measures in Xamarin.Forms
  - Blocking- COPY/PASTE feature from editable fields, blocking screen capture
- React native security:
  - https://reactnative.dev/docs/security
  - https://reactresources.com/topics/security

Discussion points

- Which of the following is a type of mobile app? Native, Hybrid, Web App, Website
- What are the pros and cons of implementing Web Apps?
- What are the similarities and differences between Cross-platform Apps and Mobile Web Apps?
- What are the security challenges in cross-platform mobile App development frameworks?
- What are the technologies used to implement each of types of mobile apps? In what circumstances can one choose to use each type of mobile app? Have a look at here or other sources and the questions.
- Read about the Google help on How to fix apps with Apache Cordova vulnerabilities; and discuss.

Practical demo

Homework

Homework

- Download and install Android SDK and Android Studio
- Prepare at least a single AVD with Android 10 or 11.
- Install Apache Cordova
- Try to build and app for Browser and Android
- Apply different XSS examples that you can find in the internet in the www/index.html file
- Then, try to modify the policy accordingly: https://blog.ostorlab.co/testing-cordova-applications.html
- Run it in the browser and Android emulator against aforementioned AVD and see if you can get XSS executed

Thank you for your attention!

andrii.shalaginov@kristiania.no